



KKMTM

2026

POLITIQUE DE SÉCURITÉ DES SYSTÈMES D'INFORMATIONS



KKMTM

DRIVING INNOVATION, ELEVATING TECHNOLOGY

Politique de Sécurité des Systèmes d'Information (PSSI)

Entreprise : KKMTM

Secteur : Industriel OT : (Laboratoire Cyber-OT) - Automobile et Aéronautique

Version : 1.3

Date : 2026-02-05

Classification : KKMTM Confidential

1. Positionnement du document

La présente PSSI constitue le document-cadre de la sécurité des systèmes d'information de KKMTM.

Cette politique est élaborée dans le cadre du projet annuel de KKMTM. L'entreprise est représentée par un laboratoire cyber-OT reproduisant une architecture industrielle réaliste afin de démontrer la faisabilité technique et organisationnelle d'un déploiement en environnement professionnel.

Elle fixe les principes, les responsabilités et les objectifs de sécurité applicables à l'ensemble de l'organisation, sans entrer dans le détail des solutions techniques retenues pour les mettre en œuvre.

Ces principes sont déclinés, avec un niveau de précision croissant, dans les documents suivants :

- Politiques thématiques : précisent l'application de la PSSI à un domaine donné
- Standards de sécurité : définissent les exigences techniques et organisationnelles à respecter (technologies, configurations de référence, architectures cibles).
- Procédures et guides opérationnels : décrivent les modes opératoires détaillés pour les équipes IT et OT.

En cas d'évolution technologique ou organisationnelle, seuls les standards et procédures ont vocation à être mis à jour fréquemment. La PSSI, elle, reste stable dans le temps.

2. Objet et périmètre

La présente PSSI définit les règles, responsabilités et objectifs de sécurité applicables à l'ensemble des systèmes d'information (SI) de l'entreprise, incluant les environnements IT, DMZ et OT, dans le but de :

- Protéger les données sensibles (plans techniques, R&D, clients, partenaires, informations financières).
- Assurer la continuité des activités industrielles et IT.
- Garantir la conformité aux normes ISO/IEC 27001, 27002, 27005, IEC 62443 et aux réglementations européennes (NIS2, RGPD, CRA).
- Définir un cadre de gestion des risques et des incidents de sécurité.

Le périmètre couvre :

- IT : postes bureautiques, serveurs internes, services d'annuaire et applications métier.

- DMZ : plateformes d'accès sécurisé, de supervision, de journalisation et de détection des incidents de sécurité.
- OT : systèmes de supervision industrielle, automates programmables, interfaces homme-machine et réseaux industriels.
- Réseau : segmentation des zones IT, DMZ et OT et sécurisation des échanges entre ces zones.

La présente politique est obligatoire pour l'ensemble des collaborateurs, prestataires et partenaires ayant accès aux systèmes d'information de KKMTM.

3. Documents de référence

- Référentiel normatif et réglementaire cybersécurité
- Plans de continuité et reprise d'activité (PCA/PRA)
- Procédures opérationnelles de sécurité
- Standards et guides techniques IT / OT

4. Rôles et responsabilités du présent document

Nom	Rôle	Responsabilités
MESQUITA SANTOS Kévin DOS	Responsable document	Garant de la cohérence et du suivi des principes de sécurité
MESQUITA SANTOS Kévin DOS	Rédacteur / Éditeur	Propose les mises à jour et assure la cohérence avec les pratiques opérationnelles
MESQUITA SANTOS Kévin DOS	Valideur	Validation formelle des évolutions du présent document
Utilisateurs	Lecteurs	Consultation du document dans le cadre de leurs activités



5. Gouvernance et responsabilités de la PSSI

- **Direction générale** : validation et support de la PSSI, arbitrage en cas de risque critique.
- **DSI (Directeur des Systèmes d'Information)** : responsable de la mise à disposition, de l'exploitation et de la performance du SI (infrastructures, applications, budget IT).
- **RSSI (Responsable Sécurité des SI)** : responsable de la définition de la politique de sécurité, de l'analyse de risques, du contrôle et de la conformité.
- **Responsables OT et IT** : application des mesures de sécurité sur leurs périmètres respectifs, suivi des incidents.
- **Utilisateurs** : respect des règles de sécurité, signalement d'incidents et bonne pratique des systèmes.

6. Classification et gestion de l'information

- **KKMTM Confidential** : plans industriels, R&D, clients, partenaires, informations financières.
- **KKMTM Internal** : procédures, documents opérationnels non sensibles.
- **Public** : communiqués, documents marketing simplifiés, FAQ externes...

Chaque document ou fichier doit être étiqueté et traité selon sa classification.

7. Gestion des accès et authentification

- Principe “**least privilege**” : chaque utilisateur ne dispose que des accès strictement nécessaires à l'exercice de son rôle.
- La gestion des comptes et des droits d'accès est centralisée et fait l'objet d'une revue périodique.
- Une authentification renforcée est exigée pour tout accès distant et pour l'accès aux systèmes sensibles ou critiques.
- Les échanges entre les zones IT, DMZ et OT sont strictement contrôlés et limités aux flux nécessaires à l'activité.



8. Sécurité réseau et systèmes

- Les réseaux IT, DMZ et OT sont segmentés logiquement et physiquement, conformément aux principes de défense en profondeur.
- Les flux inter-zones sont strictement contrôlés et tracés.
- Les systèmes IT et OT font l'objet d'une surveillance continue afin de détecter tout dysfonctionnement ou comportement anormal.
- Des mécanismes de détection et de prévention des intrusions sont déployés sur les périmètres jugés critiques.
- Les événements de sécurité sont centralisés et analysés afin de garantir une visibilité globale sur l'état de sécurité du SI.
- Les systèmes sont maintenus dans un état de sécurité conforme aux référentiels applicables (gestion des correctifs, configuration sécurisée, réduction de la surface d'attaque).
- Les accès distants aux environnements OT sont restreints, contrôlés et tracés.

9. Sécurité physique

- L'accès aux locaux sensibles (salles serveurs, salles de supervision, zones industrielles critiques) est physiquement restreint aux personnes autorisées.
- Les visiteurs et prestataires accédant à ces zones sont identifiés, enregistrés et accompagnés.
- Les équipements critiques (serveurs, automates, équipements réseau) sont protégés contre les accès non autorisés, la manipulation physique et les risques environnementaux.

10. Sécurité des tiers et prestataires

- Tout prestataire ou partenaire accédant au SI de KKMTM est soumis à des exigences de sécurité contractuelles proportionnées à la sensibilité des accès accordés.
- Les accès des tiers sont limités au strict nécessaire, tracés et revus périodiquement.
- Les prestataires intervenant sur des périmètres critiques (OT notamment) peuvent faire l'objet d'audits ou de contrôles de sécurité.

11. Continuité d'activité et sauvegarde

- Une politique de sauvegarde couvre l'ensemble des systèmes IT et OT jugés critiques pour l'activité.
- Plan de reprise d'activité (PRA) est établi et testé annuellement.
- Les composants jugés critiques font l'objet de mesures de redondance adaptées à leur niveau de criticité.
- Des procédures d'urgence sont définies pour faire face à une cyberattaque ou à une défaillance industrielle majeure.

12. Gestion des incidents

La direction et le RSSI veillent à ce que tous les incidents affectant les systèmes IT et OT soient détectés, analysés et documentés.

- Les incidents doivent être traités et escaladés selon leur criticité.
- Une traçabilité complète des incidents et des actions correctives est assurée.
- Les enseignements tirés des incidents doivent alimenter la révision des mesures de sécurité et de la PSSI.

13. Sensibilisation et formation

- Un programme de formation annuel est destiné pour l'ensemble des employés et managers.
- Des campagnes de sensibilisation sont menées sur le phishing, la sécurité des mots de passe et les risques liés aux flux industriels critiques.
- Des exercices pratiques sont organisés sur le PRA et la gestion d'incidents.

14. Conformité et audit

- Des audits internes sont réalisés annuellement sur les périmètres IT, OT, DMZ et sur les procédures associées.
- Une revue de conformité est effectuée régulièrement au regard des référentiels ISO/IEC 27001, IEC 62443, NIS2 et RGPD.
- La documentation relative aux contrôles internes et externes est centralisée.



15. Non-respect de la politique

- Le non-respect de la présente PSSI expose son auteur à des mesures disciplinaires, conformément au règlement intérieur, et, le cas échéant, à des mesures contractuelles pour les prestataires et partenaires concernés.

16. Révision et mise à jour

- La PSSI est révisée au minimum annuellement ou après tout incident majeur.
- Toute modification doit être validée conformément aux rôles et responsables du présent document et communiquée aux responsables de service.